

AI DECISION FIREWALL

Privileged Identity Containment Proof of Concept

Engineering Baseline v0.1

SYNTHETIC DATA • SIMULATED ACTIONS • NO PRODUCTION INTEGRATION

Objective

Demonstrate an executable, model-agnostic control layer that can determine whether suspicious privileged-identity activity should be closed, investigated, reversibly contained, or escalated—while keeping action authority outside the AI model.

Prepared by: Angelis Pseftis

Date: 14 August 2026

Status: Working engineering baseline

Distribution: PUBLIC / UNRESTRICTED

Document Control

Field	Value
Document title	AI Decision Firewall: Privileged Identity Containment POC — Engineering Baseline v0.1
Version	0.1.0
Technical owner	Angelis Pseftis
Baseline date	14 August 2026
Distribution	PUBLIC / UNRESTRICTED
Data boundary	Generated data only; labels stored separately from runtime inputs
Action boundary	In-memory simulator; reversible actions only
Operational status	Not authorized for production use
Primary decision requested	Approve Phase 2 historical replay and canonical data-contract discovery

Use restriction

This document and repository describe a proof of concept. No baseline result establishes operational detection accuracy, safe autonomous action, regulatory compliance, or authority to connect the system to a production identity platform.

Document Guide

Reader	Start here	Decision supported
Executive sponsor / authorizing official	Executive Summary; Sections 1–4; 17–20	Whether to fund and govern the next validation phase
Chief architect / principal engineer	Sections 5–16; Appendices A–D	Architecture, interfaces, requirements, safety case, and integration plan
SOC / identity operations	Sections 6, 11, 12, 16, and 21	Operational workflow, evidence needs, action boundaries, and analyst role
Data science / AI assurance	Sections 8–10, 16–18	Dataset limitations, model role, calibration, and evaluation design
Security assessor / red team	Sections 13–16; Appendix C	Threat model, abuse cases, verification evidence, and residual risk

Executive Summary

The unresolved AI problem is not whether a model can recommend a cyber action. It is whether the surrounding system can determine when evidence is trustworthy and sufficient, constrain the action to an authorized

boundary, prove why the action was allowed, and verify that the action produced the intended state without unacceptable mission impact.

This POC narrows that problem to privileged-identity containment. The system evaluates synthetic identity, endpoint, network, threat-intelligence, asset, change-management, workforce-context, and ticket evidence. It returns one of four dispositions: no action, investigate, reversible containment, or human escalation. The learned model is advisory; it cannot issue tokens, access credentials, change policy, or call the action target.

Baseline measure	Result	Interpretation
Synthetic test cases	400	Mechanics tested across benign, malicious, ambiguous, incomplete, break-glass, and adversarial scenarios
Reversible containment decisions	112	Only allow-listed actions against the in-memory simulator
Synthetic false containment	0	No benign synthetic case received a containment disposition
Unsafe automation	0	No action in generator-consistent cases marked poisoned, conflicted, break-glass, or above-threshold critical
Evidence traceability	100.0%	Every cited evidence and feature-trace event ID resolved to an input event
Authorization without verifier	0	No token bypassed independent verification
Audit chain	Valid	Hash continuity and record integrity verified
Median local decision latency	0.455 ms	Software execution only; excludes real telemetry and vendor APIs

What the baseline proves

The encoded authority and safety invariants are executable, testable, reproducible, and separable from the risk model. The baseline does not prove that the synthetic model will perform against real operations or that unvalidated external inputs preserve the generator's cross-field consistency.

Recommended decision

Proceed to Phase 2: de-identified historical replay and canonical data-contract discovery. Maintain a hard prohibition on live action. Use the next phase to measure evidence availability, analyst disagreement, calibration, temporal behavior, and integration risk before considering shadow mode.

1. Purpose and Objective

The POC objective is to establish a trustworthy decision-control pattern for AI-assisted cyber operations. The immediate use case is suspicious privileged-identity activity because it has meaningful mission consequence, strong multi-source observability, reversible first actions, measurable outcomes, and a safe progression from offline replay to shadow mode.

1.1 Primary Engineering Objective

Objective statement

Demonstrate that a replaceable AI or analytical model can contribute to a cyber decision without possessing the authority, credentials, or direct interface required to execute that decision.

1.2 POC Hypothesis

A model-agnostic evidence and authority layer can materially reduce the risk of unsafe AI action by separating probabilistic assessment from deterministic authorization, requiring evidence-quality and consequence thresholds, independently verifying eligibility, issuing action-scoped tokens, and validating the post-action state.

1.3 Success Is Not Defined as Model Accuracy Alone

- The model cannot directly invoke the action broker or access target credentials.
- Ground-truth labels are absent from runtime case inputs.
- Untrusted free text cannot satisfy action authority and prompt-injection content forces abstention.
- Canonical cases marked as break-glass or above the asset-criticality threshold, plus conflicted or missing evidence, are protected by explicit policy.
- Every autonomous action is allow-listed and bounded; every authorization is scoped, short-lived, and independently verified.
- Every material claim, decision, token, action, and verification result is traceable and auditable.

2. How We Got Here

The starting problem was broad: organizations want AI agents to reduce SOC burden and eventually take operational action, but they cannot reliably establish when an agent has enough trustworthy evidence or whether a proposed action is authorized and proportionate. Attempting to solve the entire SOC would create an unbounded requirements surface and make it difficult to distinguish model shortcomings from integration, evidence, policy, or authority failures.

2.1 Problem Decomposition

1. Separate analysis quality from action authority. A model may be correct and still be unauthorized to act.
2. Separate evidence content from evidence trust. A plausible event may be stale, corrupted, duplicated, adversarial, or unsupported by provenance.
3. Separate action recommendation from action execution. A correct recommendation may still exceed delegated authority or mission tolerance.
4. Separate command success from operational success. An API response does not prove the intended state or absence of collateral impact.
5. Separate synthetic mechanics validation from operational efficacy validation. Early generated data enables architecture testing but cannot support production claims.

2.2 Why Privileged Identity Was Selected

Selection criterion	Privileged identity rationale
Mission consequence	Compromised privileged access can enable broad lateral movement, cloud persistence, and control-plane manipulation.

Selection criterion	Privileged identity rationale
Observable evidence	Identity, endpoint, network, asset, change, travel, and threat-intelligence sources can be correlated.
Bounded, recoverable first actions	Session revocation, temporary step-up authentication, and enhanced monitoring can be constrained; recovery is not always exact transactional reversal.
Human authority boundary	Account disablement and endpoint isolation remain clearly human-authorized in the POC.
Measurability	Decision quality, action precision, time, rollback, and post-action state are measurable.
Generalizability	The same evidence-authority pattern can later support endpoint, cloud, network, and IT/OT boundary decisions.

2.3 Product Thesis

Durable differentiation

The defensible product is not a proprietary chatbot. It is the evidence ontology, consequence model, authority framework, independent verification, action-token protocol, replay harness, policy packs, and audit record that remain valid when the underlying model changes.

3. Decision Requested and Strategic Direction

The POC has completed the synthetic executable baseline. The next decision is whether to invest in evidence realism and operational validation without expanding action authority.

Decision	Recommendation	Rationale
Proceed to historical replay?	Yes	Required to discover schema gaps, evidence latency, class imbalance, analyst disagreement, and synthetic-to-real drift.
Connect to live production telemetry?	Not yet	First complete de-identification, data contracts, secure ingestion, privacy review, and replay acceptance criteria.
Enable live actions?	No	No operational evidence exists to support authorization. Maintain simulator-only execution.
Introduce an LLM agent?	Not in v0.2 critical path	Validate evidence, policy, and authority layers first; then compare model types behind the same interface.
Expand beyond identity?	Defer	Maintain use-case focus until replay results establish that the architecture and data contract are viable.

4. Scope, Assumptions, and Constraints

4.1 In Scope

- Synthetic privileged-identity cases and event-level evidence.
- Evidence provenance, integrity, freshness, trust, completeness, diversity, and conflict assessment.
- A replaceable learned risk model with feature-level explanation and event traceability.
- Four bounded dispositions and a deterministic policy engine.
- Independent non-model verification and signed authorization tokens.
- In-memory simulation of bounded identity actions and verification of the state returned by the simulator.
- Tamper-evident audit records, automated tests, metrics, and documentation.

4.2 Explicitly Out of Scope

- Production identity-provider, EDR, SIEM, SOAR, cloud, or ITSM connections.
- Real user, employee, incident, or classified data.
- Direct autonomous account disablement, endpoint isolation, network blocking, or persistent policy modification.
- Operational OT or cyber-physical process control.
- A general autonomous SOC agent, conversational user interface, or vendor-specific copilot replacement.
- Compliance certification, Authority to Operate, legal determination, or safety certification.

4.3 Key Assumptions

ID	Assumption	Validation needed
A-01	Privileged identity remains a high-value initial use case.	Replay workload and stakeholder interviews
A-02	Required evidence can be correlated through stable identity, device, session, and asset keys.	Canonical data-contract discovery
A-03	Low-impact actions can be made idempotent and independently verified across vendors.	Test-tenant adapter trials
A-04	Asset criticality and break-glass status are accurate enough to control authority.	CMDB and identity-governance quality assessment
A-05	Analyst adjudications can provide useful labels despite uncertainty and disagreement.	Multi-reviewer labeling study
A-06	A model-agnostic control plane is valuable even if the selected model changes.	Comparative model evaluation

5. System Architecture

The architecture is partitioned into four planes: evidence, decision, authority/action, and assurance. The control objective is to prevent any single probabilistic component from controlling evidence interpretation, authorization, execution, and verification.

5.1 System Context

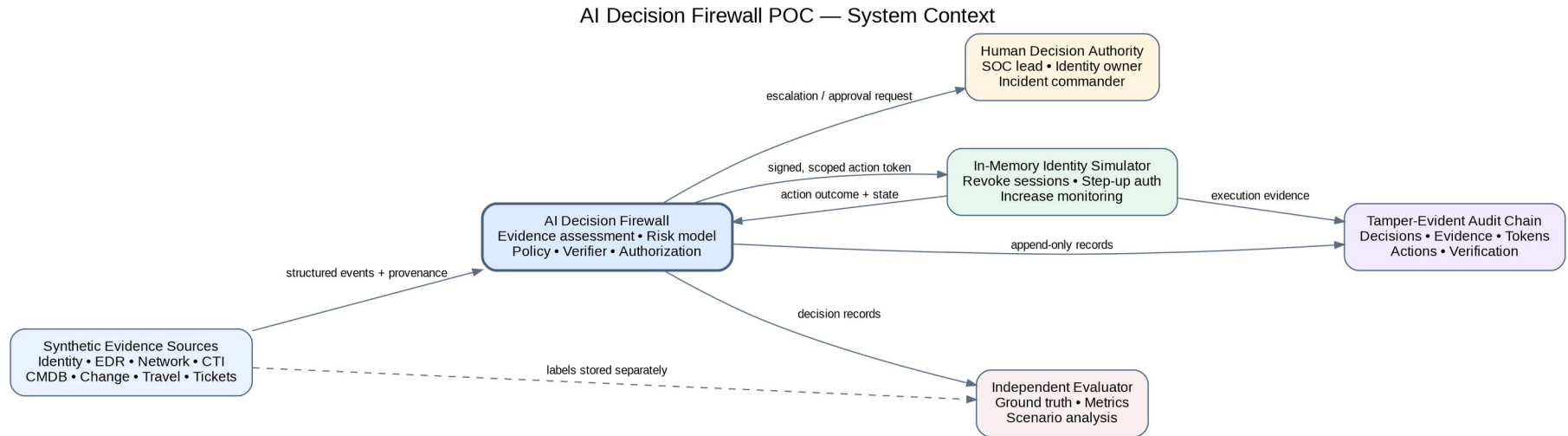


Figure 1. POC system context and external actors.

5.2 Logical Architecture

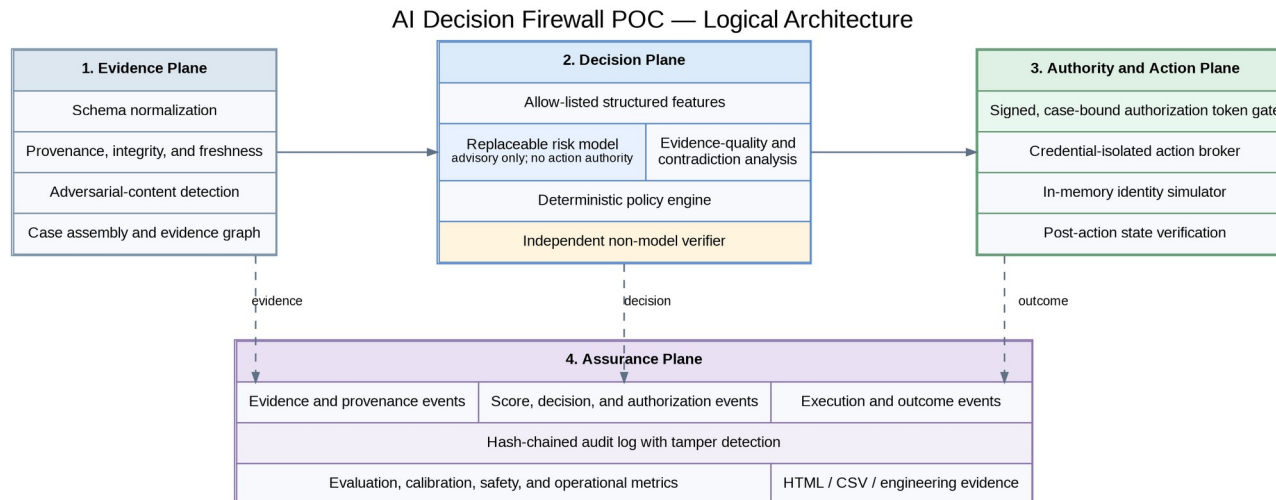


Figure 2. Four-plane logical architecture.

5.3 Decision State Machine

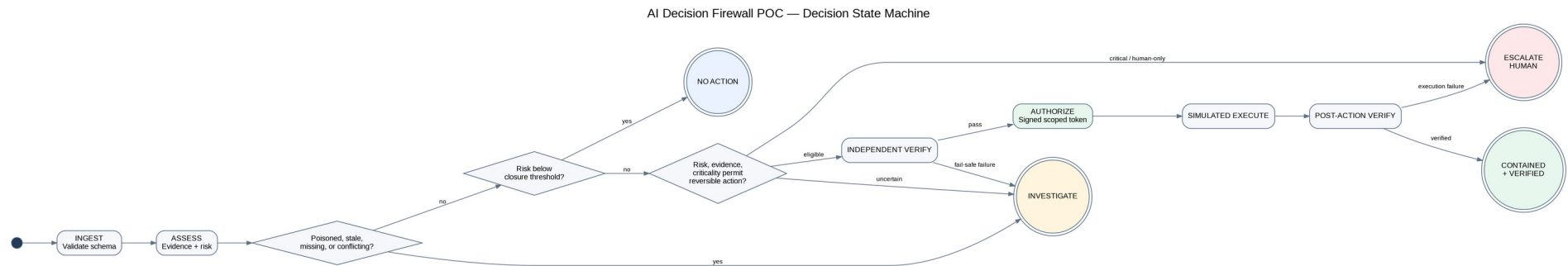


Figure 3. Fail-safe decision and action state machine.

5.4 Trust Boundaries and Data Separation

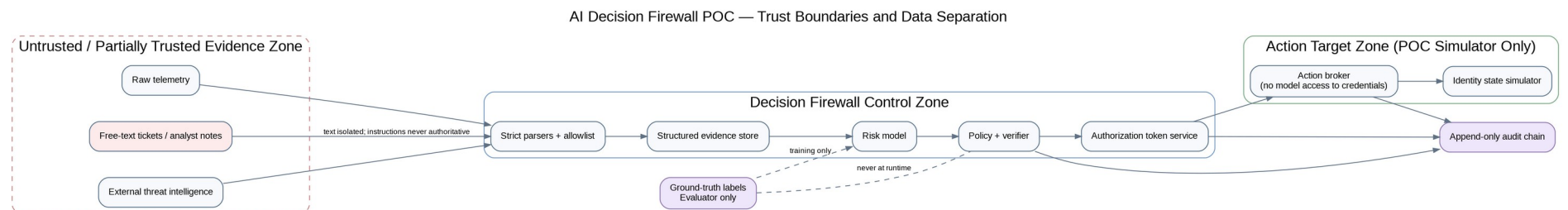


Figure 4. Trust boundaries, label separation, and credential isolation.

5.5 Component Responsibilities

Component	Responsibility	Must not do
Synthetic generator	Create reproducible cases, event evidence, and separate evaluator labels.	Represent itself as operationally realistic
Evidence assessor	Evaluate provenance, integrity, freshness, source trust, completeness, diversity, conflicts, and adversarial instructions.	Treat content plausibility as proof of trust
Feature extractor	Create allow-listed structured features and retain event-level trace.	Pass free-text instructions or ground truth to the model
Risk model	Estimate compromise probability and feature contributions.	Authorize, execute, or modify policy
Policy engine	Translate risk, evidence, criticality, and identity state into a bounded disposition.	Bypass configured authority constraints
Independent verifier	Re-evaluate containment eligibility and reject human-only or unsafe actions.	Reuse model confidence as sole evidence
Authorization gate	Mint signed, scoped, short-lived tokens after verifier approval.	Issue broad or reusable credentials
Action broker	Validate tokens and execute allow-listed simulator actions.	Accept direct model commands
Post-action verifier	Check target state against expected action outcome.	Assume API command success equals mission success
Audit logger	Record a hash-chained history of decisions and actions.	Silently alter or delete prior records
Evaluator	Join decisions with hidden labels and calculate metrics.	Expose labels to runtime components

6. Operational Concept

6.1 Actors and Authorities

Actor	Authority	POC role
Evidence producer	Submit telemetry and context	Synthetic source modules
Decision firewall	Recommend a bounded disposition	Automated pipeline
Policy owner	Define thresholds, action classes, and protected identities	Configuration owner
Independent verifier	Approve or reject autonomous-action eligibility	Deterministic software verifier
Human decision authority	Approve high-impact action or resolve uncertainty	SOC lead, identity owner, or incident commander
Action broker	Execute only actions authorized by a valid token	In-memory simulator interface

Actor	Authority	POC role
Evaluator	Measure decisions after labels are revealed	Offline metrics pipeline

6.2 Nominal Workflow

1. Receive a case and validate its schema.
2. Assess evidence trust and isolate untrusted text.
3. Extract structured features and retain event-level lineage.
4. Obtain the model probability and contributions.
5. Apply deterministic decision policy.
6. Run independent eligibility checks.
7. Issue a signed token only for allow-listed reversible actions.
8. Execute through the credential-isolated broker.
9. Verify the resulting target state.
10. Write the complete record to the audit chain and evaluator outputs.

6.3 Operating Modes

Mode	Data	Action authority	Primary objective
Development	Synthetic	Simulator only	Software, architecture, and failure-mode validation
Historical replay	De-identified prior cases	None	Data-contract, calibration, and counterfactual analysis
Shadow	Live read-only telemetry	None	Compare recommendations with analyst decisions
Controlled test tenant	Non-production identities	Explicit change-controlled reversible actions	Validate adapters, idempotency, rollback, and state verification
Limited pilot	Approved operational population	Human approval initially	Establish bounded operational evidence

7. Requirements Baseline

Requirements are organized by functional capability, safety, security, nonfunctional performance, and verification. The complete traceability matrix is included in Appendix C and in the repository as ``docs/REQUIREMENTS_TRACEABILITY_MATRIX.csv``.

7.1 Key Functional Requirements

ID	Requirement	Verification
FR-003	Assess evidence provenance, integrity, freshness, trust, diversity, completeness, and conflicts.	Scenario and unit tests

ID	Requirement	Verification
FR-004	Exclude untrusted free text from model features.	Code inspection and injection scenario
FR-006	Produce one of four bounded dispositions.	Decision summary and scenario metrics
FR-007	Perform independent non-model verification.	Unit tests and audit evidence
FR-008	Issue case-bound, action-scoped, short-lived authorization tokens.	Token and decision-record inspection
FR-010	Verify target state after action execution.	Injected action failures
FR-011	Generate tamper-evident audit records.	Audit chain and tamper test

7.2 Non-Negotiable Safety Requirements

ID	Safety invariant
SAF-001	The model has no direct action authority.
SAF-002	Poisoned evidence blocks autonomous action.
SAF-003	Break-glass identities require human authority.
SAF-004	Assets above the configured criticality boundary cannot be acted upon autonomously.
SAF-005	Human-only actions are rejected from executable action sets.
SAF-006	No action executes without a valid token.
SAF-007	No token is issued without independent-verifier approval.
SAF-008	No action is declared successful without post-action state verification.

8. Synthetic Data Design

The synthetic dataset is a test fixture, not a claim about operational prevalence. Its purpose is to create repeatable evidence combinations that exercise architecture decisions and safety boundaries, including cases that are difficult or inappropriate to manufacture in production.

8.1 Data Separation

- `train\_cases.jsonl` and `test\_cases.jsonl` contain runtime case metadata and evidence only.
- `train\_labels.jsonl` and `test\_labels.jsonl` contain scenario, compromise truth, expected disposition, and rationale.
- The decision engine receives only case files.
- The evaluator joins decisions with labels after the engine completes.
- The model training process sees only the training partition and training labels.

8.2 Canonical Evidence Event

Field	Purpose
event_id / case_id	Traceability and case association
source_type / source_instance	Source independence and adapter identity
observed_at / collected_at	Temporal ordering and freshness measurement
integrity	Verified, unverified, or failed integrity status
provenance_id	Evidence lineage identifier
trust_score	Configured source trust input
entity_refs	Identity, device, asset, session, and application correlation
attributes	Typed allow-listed evidence values
untrusted_text	Isolated context that cannot provide authority
contains_instructional_content	Adversarial-content safety signal

8.3 Scenario Catalog

Scenario	Class	Purpose
Privileged token theft	Malicious	Token reuse, new device, impossible travel, threat infrastructure, administrative activity
Password spray then success	Malicious	High failed-login intensity followed by successful privileged access
Credential dump and lateral movement	Malicious	Endpoint and network corroboration for severe post-compromise behavior
Malicious OAuth consent	Malicious	Cloud persistence and suspicious grant activity
Approved travel	Benign	Context explains geolocation anomaly
Corporate VPN geolocation	Benign	Known egress explains apparent impossible travel
Approved maintenance	Benign	Change record explains after-hours administrative behavior
Service-account batch	Benign	Known scheduled automation explains activity
Break-glass drill	Protected benign	Tests mandatory human authority
Sensor conflict	Ambiguous	Tests abstention under contradictory evidence
Telemetry gap	Ambiguous	Tests abstention when expected sources are missing
Prompt-injection poisoning	Adversarial	Tests isolation of instructions embedded in untrusted content

8.4 Data Limitations

Critical limitation

Training and test partitions originate from the same scenario generator. Therefore, model discrimination is optimistic. The POC uses those metrics only to confirm that the model interface and policy can be exercised; it does not treat them as real-world performance evidence.

9. Evidence Trust and Provenance

The system distinguishes evidence content from evidence trust. A high-risk event cannot authorize action merely because it is alarming; the event must also satisfy provenance, integrity, freshness, and corroboration requirements.

9.1 Evidence Quality Function

The v0.1 evidence-quality score is an engineering heuristic:

$$Q = 0.27P + 0.23I + 0.18F + 0.17D + 0.15T - \text{conflict, poison, and missing-source penalties}$$

Term	Meaning
P	Proportion of events with a provenance identifier
I	Proportion of events with verified integrity
F	Freshness derived from observation-to-collection delay
D	Diversity of expected evidence-source classes
T	Mean configured source-trust score

9.2 Adversarial Content Handling

- Free text is not included in model features.
- Instruction-like strings are detected independently of model reasoning.
- An event containing instructions directed at an agent is marked poisoned for authority purposes.
- Poisoned evidence forces `INVESTIGATE`; it cannot satisfy autonomous-containment policy.
- Future natural-language extraction must produce typed claims with provenance and remain subordinate to the same policy gate.

10. Model Design and Role

The baseline model is intentionally simple and interpretable. It demonstrates that a learned recommender can be integrated without allowing the model to dominate authority. A future LLM, graph model, ensemble, or vendor agent must use the same assessment interface and remain subject to the same controls.

10.1 Model Form

$$p(\text{compromise} \mid \text{evidence}) = \sigma(\mathbf{w}^T \mathbf{z} + \mathbf{b})$$

Features are standardized using training-partition statistics. Batch gradient descent with L2 regularization fits the weights. The model emits probability, the strongest positive and negative feature contributions, and the source events supporting each feature.

10.2 Feature Boundary

Included structured features	Excluded inputs
Failed-login intensity; new device; impossible travel; threat-IP match; MFA fatigue; token reuse; credential dumping; lateral movement; unusual admin action; EDR malware; after-hours activity; privilege level; asset criticality; VPN, travel, maintenance, and service-account context; strong MFA; device compliance; OAuth grant.	Free-text instructions; scenario name; expected disposition; ground truth; raw credentials; user display name; analyst command text; action credentials.

10.3 Model Authority Restrictions

Hard boundary

The model returns an assessment object. It does not hold the HMAC signing key, target credentials, an action-broker reference, a policy-modification interface, or a route to the simulator.

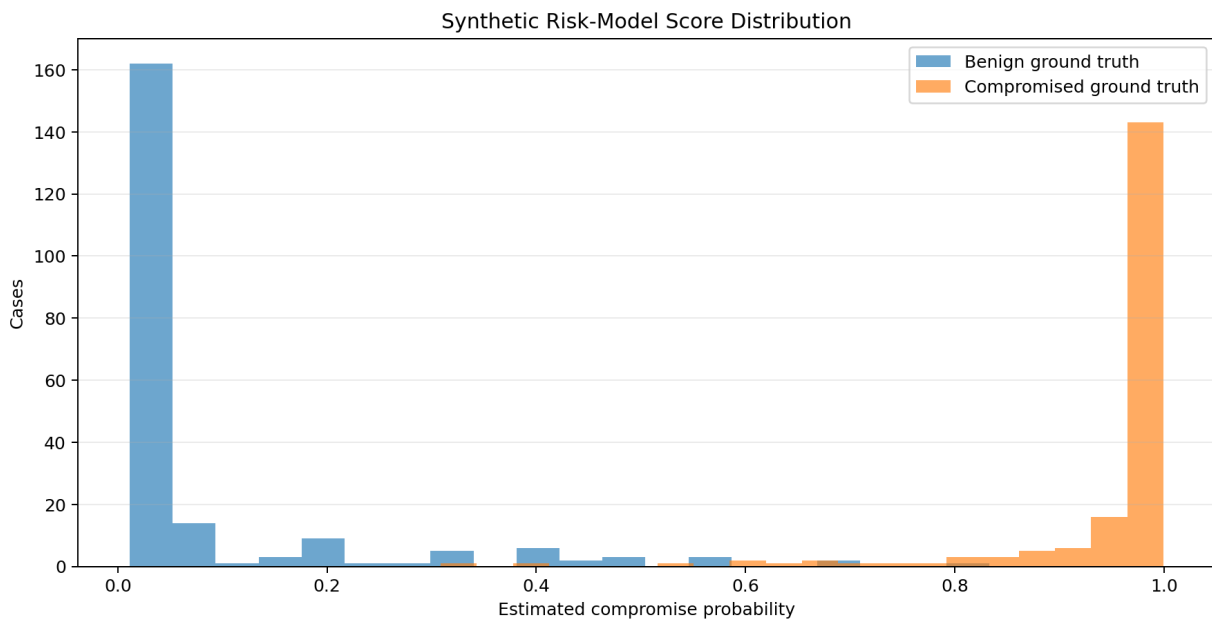


Figure 5. Synthetic risk-score distribution. The separation is optimistic because the same generator family produced training and test partitions.

11. Decision Policy

The decision policy combines model probability with evidence quality, independent corroboration, protected identity status, asset criticality, conflict state, and action class. The policy is external configuration and is recorded in each decision.

11.1 Four Dispositions

Disposition	Entry condition	Permitted system behavior
NO_ACTION	Decision-grade evidence; risk at or below 0.24; no severe indicator	Close with evidence and rationale; no operational action
INVESTIGATE	Evidence missing, stale, conflicted, poisoned, low integrity, or risk uncertain	Issue read-only evidence-collection tasks
CONTAIN_REVERSIBLE	Risk at or above 0.88; decision-grade evidence; at least two supporting source classes; asset criticality at or below 0.75; not break glass	Mint token for three allow-listed simulator actions after verifier approval
ESCALATE_HUMAN	Risk at or above 0.62, severe behavior, critical asset, break-glass identity, or human-only action	Recommend action and route authority to a human role

11.2 Current POC Action Classes

Class	Actions	Authority
Autonomous POC allowlist	Revoke active sessions; require temporary step-up authentication; increase monitoring	Signed token after independent verification
Human-only	Disable account; isolate endpoint; block network path; modify persistent access policy	Explicit authorized human decision
Read only	Query identity history; query endpoint telemetry; validate change and travel context	Read-only automation

11.3 Future Consequence-Based Policy

The fixed thresholds are sufficient for a POC. A production design should explicitly minimize expected mission loss rather than optimize a generic classification threshold:

$$a^* = \operatorname{argmin}_a [P(C|E)L_{\text{miss}}(a) + P(-C|E)L_{\text{false}}(a) + L_{\text{mission}}(a)]$$

The loss terms must be action-specific, mission-specific, and approved by the policy owner. They cannot be inferred solely from model confidence.

12. Authorization, Execution, and Verification

12.1 Independent Verification

The verifier re-evaluates containment eligibility without using the model as its sole source of truth. It validates probability range, event traceability, action allowlists, evidence thresholds, source corroboration, conflict state, poisoned evidence, break-glass status, asset criticality, and rollback coverage.

12.2 Authorization Token

Token property	POC implementation
Integrity	HMAC-SHA-256 signature
Scope	Case ID and exact permitted actions
Binding	Hash of disposition, actions, rules, and cited evidence IDs
Lifetime	120 seconds
Issuance condition	Independent verifier passes and executable actions exist
Validation	Signature, case, action membership, and expiration checked by broker

12.3 Action Simulator

The action target is an in-memory identity-state object. It has no external network connector. The simulator tracks active sessions, temporary step-up authentication, monitoring level, and account-enabled state. It deliberately injects deterministic downstream failures so that the POC exercises post-action failure handling.

12.4 Post-Action Verification

Action	Expected state
Revoke active sessions	active_sessions = 0
Force step-up authentication	step_up_required = true
Increase monitoring	monitoring_level = enhanced

In v0.1, this check evaluates the state returned by the same in-memory simulator call. It is not an independent readback from a target system, and rollback plans are descriptive metadata rather than executable rollback orchestration.

13. Security and Safety Architecture

The top-level safety claim is that the POC cannot autonomously perform a consequential identity action unless deterministic policy and independent verification establish that the case, evidence, asset, identity, and action satisfy the configured reversible-action boundary.

13.1 Security Controls Implemented

- Module-level separation between model, policy, verifier, authorization gate, broker, and target.
- Allow-listed structured feature extraction.
- Free-text isolation and instruction detection.
- HMAC integrity protection for authorization tokens.
- Case and action scoping with expiration.
- Human-only action denylist enforced by the verifier.
- Hash-chained audit log and tamper detection.
- No production connector, secret, credential, or target endpoint.

13.2 Residual Security Limitations

Limitation	Consequence	Required next control
POC signing-key fallback	Not appropriate for production key custody	External secrets manager or HSM; rotation; dual control
Synthetic provenance identifiers	Do not establish real source authenticity	Collector signing, secure transport, and attested source identity
Policy and verifier share configuration	Potential common-mode specification defect	Independent policy representation and diverse verification implementation
Single-process runtime	Weak fault and privilege isolation	Process or service isolation, least privilege, sandboxing, and mTLS
In-memory target	Does not model vendor API or distributed-state behavior	Test-tenant adapters, retries, idempotency, rate limits, and eventual-consistency checks
No operator identity or approval workflow	Cannot establish accountable human authorization	Strong operator authentication, RBAC/ABAC, approval records, and nonrepudiation

14. Threat Model and Abuse Cases

Threat / abuse case	Failure sought	POC control	Residual risk
Prompt injection in ticket or log text	Convince an agent to disable an account	Text excluded from features; instruction detection; forced abstention	Structured-field poisoning remains possible
Missing or forged provenance	Elevate untrusted evidence	Provenance and integrity thresholds	Synthetic IDs are not cryptographically rooted
Correlated sensors	Create false appearance of independent corroboration	Source-type diversity count	Vendor or pipeline common cause not yet modeled
Compromised CMDB criticality	Lower protection on mission-critical asset	Criticality is policy input and audit field	Needs authoritative source, change control, and independent validation
Model overconfidence	Cross containment threshold on weak evidence	Evidence gate, independent verifier, criticality and action restrictions	Threshold calibration not operationally validated
Token theft or replay	Execute previously approved action	Short TTL, case/action scope, signature	No nonce store or replay cache in v0.1
Broker bypass	Call target without policy	Broker rejects missing or invalid token	Single-process POC lacks OS-level enforcement
False API success	Declare containment complete when state did not change	Post-action state verification	Real vendor state may be delayed or partially observable
Audit modification	Hide unsafe decision	Hash chain and verification	No external timestamping or immutable storage
Ground-truth leakage	Artificially inflate model performance	Separate files and runtime interfaces	Training pipeline access still requires governance

15. Implementation Baseline

The POC is a local Python 3.11+ package with NumPy as its only runtime dependency. The end-to-end command generates data, trains the model, runs the engine, evaluates results, verifies the audit chain, and produces JSONL, JSON, CSV, and HTML artifacts.

15.1 Repository Modules

Module	Purpose
synthetic.py	Scenario generator and separated labels
schemas.py	Evidence, case, ground-truth, and disposition structures
features.py	Allow-listed structured features and event trace
evidence.py	Evidence trust, conflict, and adversarial-content assessment
model.py	Interpretable logistic model and model artifact
policy.py	Deterministic four-way decision policy
verifier.py	Independent action-eligibility verification
actions.py	Authorization gate, token validation, broker, simulator, and post-action verification
audit.py	Append-only hash-chained audit log
engine.py	End-to-end decision orchestration
metrics.py	Evaluation metrics and CSV artifacts
reporting.py	Self-contained HTML dashboard
run_poc.py	Reproducible end-to-end entry point

15.2 Reproduction Command

```
python -m venv .venv
pip install -r requirements.txt
python run_poc.py
PYTHONPATH=src python -m unittest discover -s tests -v
```

16. Verification and Validation

16.1 Test Strategy

Category	Focus
Functional	Ingestion, assessment, policy, verification, token issuance, action, post-action verification, audit, and reporting
Safety	Poisoned evidence, break glass, criticality, human-only actions, missing tokens, and authorization bypass
Security	Token integrity, traceability, audit tamper detection, and label separation

Category	Focus
Model	Discrimination, calibration, false positives, false negatives, and scenario behavior
Failure injection	Synthetic target-command failures and post-action detection
Reproducibility	Fixed seed, manifests, model artifact, policy version, and deterministic dataset generation

16.2 Automated Test Results

Test	Result
Ground truth is absent from runtime case input	Pass
Small end-to-end run preserves safety invariants	Pass
Action broker rejects missing token	Pass
Audit chain detects tampering	Pass
Break-glass identity never auto-contains	Pass
Poisoned evidence forces abstention	Pass
Verifier rejects human-only action	Pass

Test result

Seven of seven automated tests passed in the delivered baseline. The test suite prioritizes safety invariants over synthetic model accuracy.

17. Baseline Results

The baseline used seed 20260814, 800 synthetic training cases, and 400 synthetic test cases. The model artifact, policy, decisions, audit chain, metrics, test output, and HTML dashboard are included in `outputs/baseline/`.

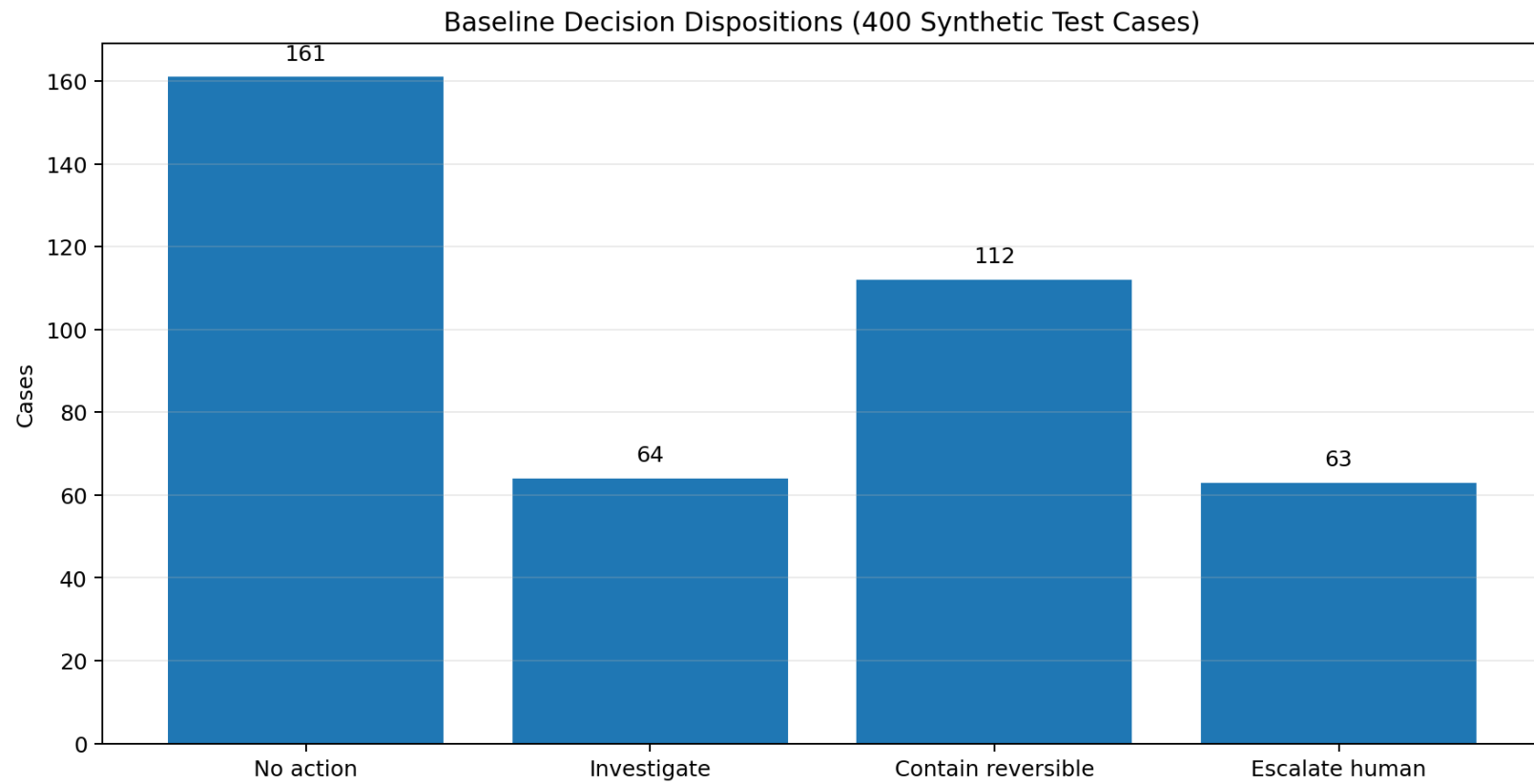


Figure 6. Baseline disposition counts.

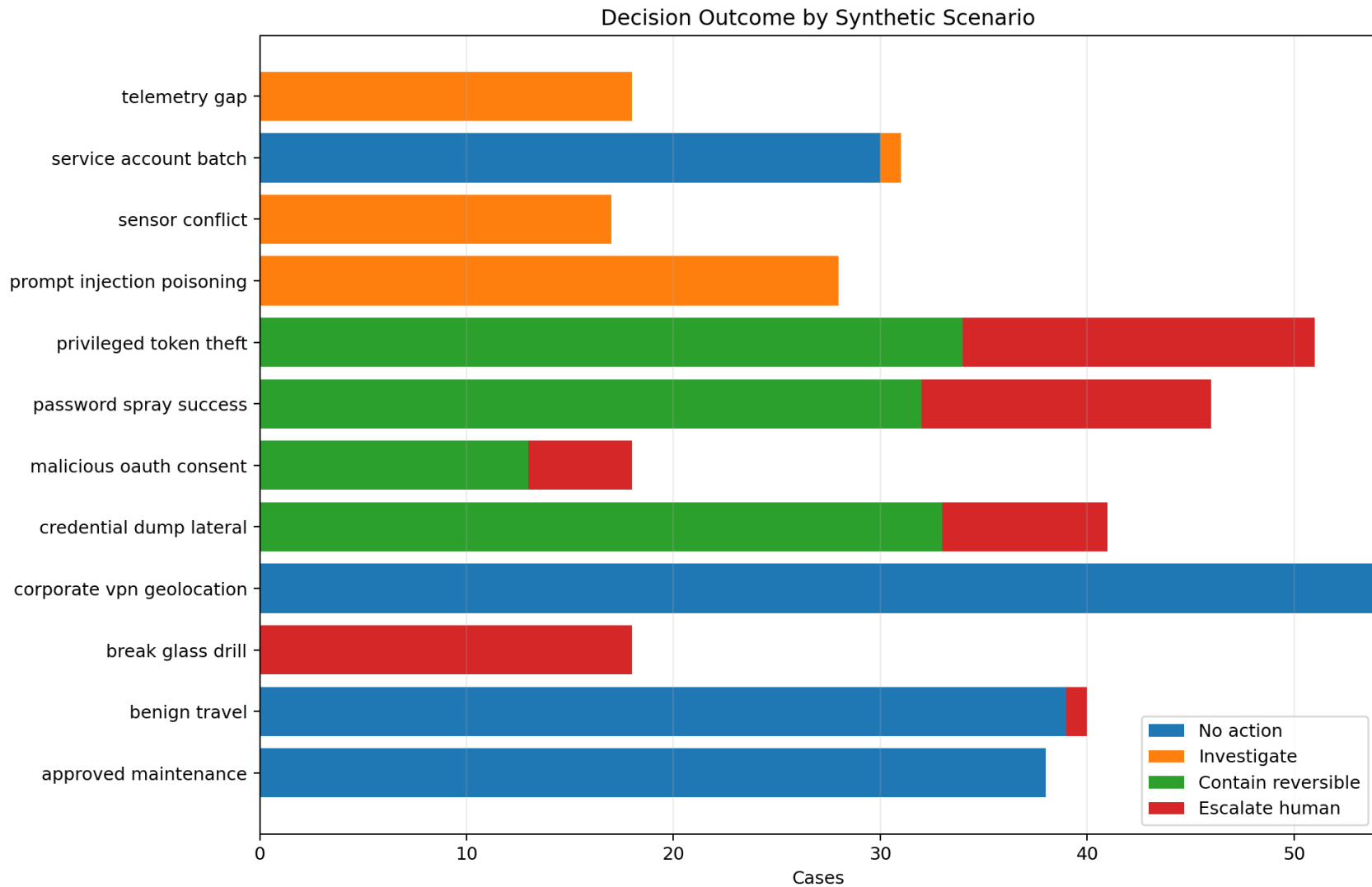


Figure 7. Decision outcome by synthetic scenario.

17.1 Decision-Control Metrics

Metric	Result
Expected disposition match rate	98.75%
Autonomous containment count	112
Autonomous containment precision	100.00%
False containment count	0
Compromise autonomous-containment coverage	59.89%
Compromise contain-or-escalate coverage	83.42%
Investigation / abstention rate	16.00%

17.2 Safety and Assurance Metrics

Metric	Result
Unsafe automation count	0
Poisoned-evidence cases	28
Poisoned-evidence autonomous actions	0
Authorization without independent verifier	0
Evidence traceability	100.00%
Action-command success	97.62%
Complete post-action verification pass rate	92.86%
Audit chain	Valid

17.3 Model Metrics — Synthetic Only

Metric	Result
Accuracy at 0.5	98.00%
Precision at 0.5	96.86%
Recall at 0.5	98.93%
F1 at 0.5	0.9788
ROC AUC	0.9984
Brier score	0.0206
10-bin expected calibration error	0.0447

Interpretation

The high synthetic model metrics are expected because the train and test sets share the same generator family. They validate the code path, not operational performance. The more consequential baseline results are zero recorded authority bypass, zero unsafe automation under the encoded generator-consistent tests, complete event-ID reference checks, and successful detection of simulated action failures.

18. Limitations and Open Questions

Gap	Why it matters	Resolution path
Synthetic-to-real distribution shift	Real telemetry, attack behavior, and benign context will differ materially.	Historical replay, temporal holdout, source ablation, and shadow mode
Ground-truth uncertainty	Incident labels are often incomplete or disputed.	Multi-reviewer adjudication, confidence labels, and unresolved class
Source independence	Multiple tools may derive from the same upstream sensor or rule.	Provenance graph and common-cause analysis
Delayed evidence	Important context may arrive after the initial decision.	Event-time processing, decision revision, and evidence-aging policy
Mission consequence model	The same action has different costs across assets and missions.	Asset-owner consequence workshops and action-specific loss models
Policy common-mode error	Policy and verifier may encode the same flawed assumption.	Diverse verifier implementation, formal constraints, and red-team review
Canonical-context consistency	V0.1 trusts top-level break-glass and asset-criticality fields and does not reconcile conflicting event values.	Versioned replay contract, cross-field validation, and fail-closed rejection
Target-state observation	V0.1 verifies the simulator response rather than an independent target readback.	Read-after-write adapter contract and independently sourced observation
Authorization and recovery hardening	The fallback key is public; token replay control, external audit anchoring, and executable rollback are absent.	Secrets management, one-time tokens, external audit anchor, and rollback tests
Vendor action semantics	Session revocation and step-up behavior vary by platform.	Test-tenant adapters and contract tests
Human factors	Analyst trust, overreliance, and approval fatigue can defeat technical controls.	Workflow study, reason codes, disagreement capture, and stop conditions
Privacy and records handling	Identity telemetry may contain regulated or sensitive data.	Data minimization, pseudonymization, access control, retention, and legal review

19. Where We Are Going

Phase	Data / integration	Action level	Exit criterion
0 — Concept convergence	Problem decomposition and use-case selection	None	Bounded objective and product thesis
1 — Synthetic executable baseline	Generated multi-source evidence	Simulator only	Safety invariants executable and reproducible

Phase	Data / integration	Action level	Exit criterion
2 — Historical replay	De-identified cases and canonical adapters	None	Evidence coverage, calibration, disagreement, and data gaps quantified
3 — Live shadow mode	Approved read-only live feeds	None	Stable schemas, analyst comparison, bounded false-containment estimate
4 — Controlled test tenant	Non-production identity integrations	Change-controlled reversible actions	Idempotency, rollback, token, and state verification validated
5 — Limited pilot	Small approved operational population	Human approval initially	Authorizing official accepts bounded residual risk
6 — Productization	Multi-vendor, multi-tenant, sector policy packs	Action-class specific	Operational support, governance, secure updates, and evidence lifecycle

19.1 Next 90 Days

Window	Primary work	Concrete outputs
Days 0–30	Governance, data-use agreement, case taxonomy, canonical event schema, replay environment, and adjudication procedure	Approved data contract; privacy/security plan; 50-case pilot corpus; updated threat model
Days 31–60	Historical ingestion, vendor adapters, evidence coverage analysis, analyst labeling, temporal replay, source ablation	250–500 replay cases; adapter test suite; schema-gap report; initial calibration report
Days 61–90	Counterfactual comparison, policy tuning, independent review, shadow-mode readiness assessment	V0.2 baseline; release-gate recommendation; shadow-mode test plan; stop conditions

20. Immediate Implementation Plan

1. Freeze v0.1 as a reproducible baseline and tag the source repository.
2. Select one identity platform and one EDR source for canonical adapter discovery; do not build production credentials or write access.
3. Obtain 50–100 de-identified cases spanning true compromise, benign administration, unresolved alerts, and known false positives.
4. Define minimum case evidence and mark every field as required, optional, derived, sensitive, or prohibited.
5. Create a two-reviewer adjudication process with disagreement and confidence capture.
6. Run the v0.1 pipeline unmodified against mapped replay data to expose schema and assumption failures before tuning the model.
7. Perform source-ablation and delayed-evidence tests to determine which sources are actually decision critical.
8. Revise thresholds only after documenting the cost of false containment, missed compromise, investigation burden, and mission disruption.
9. Commission an independent safety and red-team review of policy, verifier, token, and audit controls.
10. Prepare a shadow-mode readiness decision package; maintain zero live action authority.

21. Data Required for the Next Phase

The next phase requires data sufficient to reconstruct what was known at each decision point, not merely a final incident summary. Timestamps, source identity, and decision context are essential.

Domain	Minimum fields	Purpose
Identity	Pseudonymous subject ID; event and collection time; source IP; device ID; application; auth result; MFA method/result; session/token hash; risk flags; privilege state	Authentication sequence, token misuse, and identity context
Endpoint	Device ID; event time; process and parent hashes; credential-access indicator; malware verdict; device compliance; user-session link	Corroborate credential access and endpoint state
Network / DNS / proxy	Event time; source/destination; domain; protocol; VPN/proxy attribution; geo-confidence; session or device correlation	Differentiate threat infrastructure from benign routing artifacts
Threat intelligence	Indicator; type; source; confidence; first/last seen; expiration; provenance	Assess whether a match is current and independently sourced
Asset / identity governance	Owner; environment; mission/business function; criticality; break-glass status; privilege type; dependencies	Determine consequence and authority boundary
Change / maintenance	Change ID; approved window; identities; assets; intended actions; approver; status	Disconfirm alerts caused by authorized administration
Travel / workforce context	Pseudonymous subject; authorized travel window; coarse location; device assignment	Explain geolocation anomalies while minimizing privacy exposure
Analyst decision	Decision time; disposition; evidence used; evidence requested; confidence; reviewer; reason code	Measure agreement, burden, and missing evidence
Incident ground truth	Confirmed compromise state; discovery basis; affected identities/assets; timeline; uncertainty	Outcome evaluation with confidence rather than false certainty
Action and recovery	Action; authority; request and completion time; API result; verified target state; rollback; business impact	Validate execution, side effects, and actual outcome

21.1 Data Governance Requirements

- Pseudonymize users and hash session, token, device, and indicator identifiers where feasible.
- Retain event time and collection time separately.
- Preserve original source and transformation provenance.
- Restrict sensitive workforce context to the minimum granularity needed for the decision.
- Separate model-development access from evaluator labels and final adjudication.
- Define retention, deletion, redisclosure, incident-notification, and audit requirements before ingestion.

22. Program Risk Register

ID	Risk	Likelihood	Impact	Mitigation / trigger
R-01	Synthetic results create false confidence	High	High	Place limitation beside every result; prohibit operational claims; require replay release gate

ID	Risk	Likelihood	Impact	Mitigation / trigger
R-02	Historical labels are incomplete or biased	High	High	Two-reviewer adjudication, uncertainty class, evidence-based label confidence
R-03	Evidence cannot be reliably correlated	Medium	High	Canonical identity/device/session keys; adapter quality metrics; reject low-linkage cases
R-04	CMDB criticality is stale	High	High	Authoritative ownership, freshness, independent validation, and conservative default
R-05	Model and policy are tuned to the replay corpus	Medium	High	Temporal holdout, blind evaluation, change control, and external review
R-06	Operator pressure expands action authority too early	Medium	Critical	Governance charter, technical deny controls, authorizing-official gate, kill switch
R-07	Prompt injection migrates to structured fields	Medium	High	Typed schemas, source authentication, range validation, cross-source consistency, red team
R-08	Vendor API action is non-idempotent or partially applied	Medium	High	Test tenant, idempotency keys, retries, state verification, rollback, stop conditions
R-09	Identity telemetry creates privacy or labor risk	Medium	High	Minimization, legal/privacy review, access controls, purpose limitation, retention
R-10	Common-mode defect in policy and verifier	Medium	High	Diverse implementation, formal constraints, independent assessment, fault injection

23. Standards and Framework Alignment

The POC uses standards as engineering references, not as a claim of compliance or certification. NIST AI RMF provides the Govern, Map, Measure, and Manage risk-management functions [1]. The Generative AI Profile emphasizes risks that include confabulation, information integrity, data privacy, and human-AI configuration [2]. NIST SP 800-160 provides a systems-security-engineering basis for trustworthy systems [3]. NIST SP 800-61 Rev. 3 integrates incident response into cybersecurity risk management [4]. Zero Trust Architecture reinforces explicit, resource-focused authentication and authorization without implicit trust [5]. NIST SP 800-53 provides control families relevant to access enforcement, audit, monitoring, incident handling, integrity, configuration management, and system development [6]. MITRE ATT&CK informs the valid-account, credential-access, and lateral-movement scenario logic [7–9].

Reference area	POC application
NIST AI RMF — Govern	Roles, authority boundaries, policy ownership, action classification, and documented limitations

Reference area	POC application
NIST AI RMF — Map	Use-case scope, affected actors, mission consequence, data provenance, and context
NIST AI RMF — Measure	Calibration, false containment, abstention, traceability, red-team cases, and post-action outcome
NIST AI RMF — Manage	Risk treatment, release gates, stop conditions, human escalation, and continuous review
NIST SP 800-160	Trustworthiness objectives, separation, assurance evidence, lifecycle engineering, and contested-environment thinking
NIST SP 800-61 Rev. 3	Detection, response, recovery, evidence collection, and continuous improvement
NIST SP 800-207	Explicit authentication and authorization at the identity, device, and resource boundary
NIST SP 800-53 Rev. 5	AC, AU, CA, CM, IA, IR, SA, SI, and SR control-family considerations
MITRE ATT&CK	Scenario coverage for valid accounts, credential access, OAuth/cloud access, and lateral movement

24. Conclusion and Recommendation

The POC establishes the beginning of a trusted AI action architecture. It demonstrates that evidence trust, model assessment, policy, verification, authorization, execution, and outcome validation can be separated and made observable. That separation is the core technical requirement for using AI in consequential cyber operations without making model confidence equivalent to authority.

The correct next move is not to add more autonomy. It is to add evidence realism. Historical replay should challenge the current assumptions, quantify what evidence is actually available at decision time, expose correlated sources and missing context, and determine whether the identity use case can support a defensible shadow-mode experiment.

Recommendation

Approve Phase 2 historical replay and data-contract discovery under a no-live-action constraint. Preserve the model-agnostic authority boundary. Do not authorize production actions until replay, shadow mode, test-tenant execution, independent review, and action-specific statistical release gates are complete.

Appendix A. Repository and Output Inventory

Path	Description
README.md	Quick start, architecture summary, baseline results, and limitations
config/policy.json	Thresholds, evidence requirements, action classes, and safety controls
data/*.jsonl	Synthetic training/test cases and separate ground-truth labels
src/adf_poc/	POC implementation modules
tests/	Safety and pipeline tests
outputs/baseline/model.json	Trained synthetic model artifact
outputs/baseline/decisions.jsonl	Full decision records
outputs/baseline/audit_chain.jsonl	Hash-chained audit records
outputs/baseline/metrics.json	Full baseline metrics
outputs/baseline/decision_summary.csv	Case-level evaluator summary
outputs/baseline/per_scenario_metrics.csv	Scenario-level outcome metrics
outputs/baseline/baseline_report.html	Self-contained evaluation dashboard
docs/	Engineering plan, data card, model card, safety case, test plan, roadmap, ADRs, and diagrams

Appendix B. Disposition and Scenario Baseline

Scenario	Cases	Comp.	No action	Investigate	Contain	Escalate	Expected match
approved_maintenance	38	0	38	0	0	0	100.0%
benign_travel	40	0	39	0	0	1	100.0%
break_glass_drill	18	0	0	0	0	18	100.0%
corporate_vpn_geolocation	54	0	54	0	0	0	100.0%
credential_dump_lateral	41	41	0	0	33	8	100.0%

Scenario	Cases	Comp.	No action	Investigate	Contain	Escalate	Expected match
malicious_oauth_consent	18	18	0	0	13	5	100.0%
password_spray_success	46	46	0	0	32	14	93.5%
privileged_token_theft	51	51	0	0	34	17	100.0%
prompt_injection_poisoning	28	13	0	28	0	0	96.4%
sensor_conflict	17	6	0	17	0	0	100.0%
service_account_batch	31	0	30	1	0	0	96.8%
telemetry_gap	18	12	0	18	0	0	100.0%

Appendix C. Requirements Traceability Matrix

Requirement ID	Type	Requirement	Implementation	Verification Method	Baseline Result
OBJ-001	Objective	Demonstrate a defensible decision-control layer for privileged-identity containment using synthetic data.	Entire POC package	End-to-end baseline run	Pass
FR-001	Functional	Ingest case records containing multi-source evidence events.	schemas.py and engine.py	Pipeline test	Pass
FR-002	Functional	Store ground truth separately from runtime case inputs.	synthetic.py	Dataset unit test	Pass
FR-003	Functional	Assess evidence provenance integrity freshness trust diversity completeness and conflicts.	evidence.py	Unit and scenario evaluation	Pass
FR-004	Functional	Exclude untrusted free text from model features.	features.py	Code inspection and poison scenario	Pass
FR-005	Functional	Estimate compromise probability using a replaceable model.	model.py	Model training and test metrics	Pass
FR-006	Functional	Produce one of four bounded dispositions.	policy.py	Decision summary and scenario metrics	Pass
FR-007	Functional	Perform independent non-model verification.	verifier.py	Unit test and audit records	Pass
FR-008	Functional	Issue case-bound action-scoped short-lived authorization tokens.	actions.py	Pipeline test and decision records	Pass

Requirement ID	Type	Requirement	Implementation	Verification Method	Baseline Result
FR-009	Functional	Execute only allow-listed simulated reversible actions.	actions.py	Unit tests and action results	Pass
FR-010	Functional	Verify target state after action execution.	actions.py and engine.py	Post-action metrics	Pass
FR-011	Functional	Generate tamper-evident audit records.	audit.py	Audit verification and tamper test	Pass
SAF-001	Safety	The model shall have no direct action authority.	Module separation and token gate	Architecture inspection	Pass
SAF-002	Safety	Poisoned evidence shall block autonomous action.	evidence.py and policy.py	Prompt-injection unit test	Pass
SAF-003	Safety	Break-glass identities shall require human authority.	policy.py and verifier.py	Break-glass unit test	Pass
SAF-004	Safety	Assets above the criticality threshold shall not be autonomously acted upon.	policy.py and verifier.py	Safety metrics	Pass
SAF-005	Safety	Human-only actions shall be rejected from executable action sets.	verifier.py	Human-only action unit test	Pass
SAF-006	Safety	No action shall execute without a valid token.	ActionBroker	Missing-token unit test	Pass
SAF-007	Safety	No token shall be issued without independent-verifier approval.	AuthorizationGate	Metrics and audit inspection	Pass
SAF-008	Safety	No success shall be declared without post-action state verification.	PostActionVerifier	Injected execution failures	Pass
SEC-001	Security	Authorization tokens shall be integrity protected.	HMAC SHA-256 signatures	Code inspection and validation path	Pass for POC
SEC-002	Security	Audit records shall be hash chained.	AuditLogger	Audit-chain verifier and tamper test	Pass
SEC-003	Security	Feature and evidence claims shall trace to source event identifiers.	features.py and decision record	Traceability metric	Pass at 100 percent
SEC-004	Security	The POC shall not contain a production connector or production credentials.	In-memory simulator only	Code and repository inspection	Pass
NFR-001	Nonfunctional	A baseline run shall be reproducible from a documented seed.	run_poc.py and dataset manifest	Repeat run with seed	Pass
NFR-002	Nonfunctional	The POC shall run offline after dependencies are installed.	Local Python and NumPy implementation	Execution test	Pass
NFR-003	Nonfunctional	The system shall emit machine-readable and human-readable outputs.	JSONL JSON CSV and HTML reports	Artifact inspection	Pass

Requirement ID	Type	Requirement	Implementation	Verification Method	Baseline Result
NFR-004	Nonfunctional	The design shall be model agnostic.	Model adapter boundary and policy separation	Architecture review	Pass
VV-001	Verification	Automated tests shall cover core safety invariants.	tests directory	Unit test execution	7 of 7 pass
VV-002	Verification	Scenario metrics shall identify behavior by benign malicious ambiguous and adversarial scenario.	metrics.py	per_scenario_metrics.csv	Pass
VV-003	Verification	Baseline limitations shall be stated with the results.	README docs and HTML report	Document review	Pass

Appendix D. Glossary

Term	Definition
Abstention	A deliberate decision not to close or act because evidence or confidence is insufficient.
Action authority	The delegated right to cause a change in an operational system.
Action broker	Credential-isolated component that validates authorization and calls the target interface.
Decision-grade evidence	Evidence meeting minimum provenance, integrity, freshness, completeness, diversity, and conflict requirements for a disposition.
Evidence provenance	Information identifying the source, collection path, and transformations associated with evidence.
Independent verifier	Non-model component that re-evaluates action eligibility against deterministic constraints.
Model-agnostic	Architecture that can replace the analytical model without changing the authority and safety boundary.
Poisoned evidence	Untrusted content or structured data intended to manipulate analysis or action beyond its evidentiary role.
Post-action verification	A check that the target reached the intended state after an action. V0.1 checks the state returned by its simulator; later phases require independent target readback.
Reversible containment	A bounded low-impact action with defined restoration or recovery behavior; the recovery path may not recreate the original state exactly.
Shadow mode	Live read-only operation in which recommendations are measured but no operational actions are allowed.

Appendix E. References

- [1] National Institute of Standards and Technology, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, January 2023. <https://doi.org/10.6028/NIST.AI.100-1>
- [2] National Institute of Standards and Technology, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, July 2024. <https://doi.org/10.6028/NIST.AI.600-1>
- [3] National Institute of Standards and Technology, Engineering Trustworthy Secure Systems, NIST SP 800-160 Vol. 1 Rev. 1, November 2022. <https://doi.org/10.6028/NIST.SP.800-160v1r1>
- [4] National Institute of Standards and Technology, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile, NIST SP 800-61 Rev. 3, April 2025. <https://doi.org/10.6028/NIST.SP.800-61r3>
- [5] National Institute of Standards and Technology, Zero Trust Architecture, NIST SP 800-207, August 2020. <https://doi.org/10.6028/NIST.SP.800-207>
- [6] National Institute of Standards and Technology, Security and Privacy Controls for Information Systems and Organizations, NIST SP 800-53 Rev. 5, including Release 5.2.0 materials. <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- [7] MITRE ATT&CK, Valid Accounts, Technique T1078. <https://attack.mitre.org/techniques/T1078/>
- [8] MITRE ATT&CK, Credential Access, Tactic TA0006. <https://attack.mitre.org/tactics/TA0006/>
- [9] MITRE ATT&CK, Lateral Movement, Tactic TA0008. <https://attack.mitre.org/tactics/TA0008/>